

AdminShop

Protótipo de Autenticação Segura

Painel administrativo interno de uma loja virtual — vendedores, financeiro e administradores

SEGURANÇA · AUTENTICAÇÃO · RBAC · MFA

O cenário

- Painel de bastidores de uma loja virtual — não é a loja que o cliente final acessa.
- Usado só por funcionários: vendedores, financeiro e administradores.
- Quem entra tem acesso a dados de pagamento e dados pessoais de clientes que nunca deram consentimento para aquele funcionário específico ver.



VENDEDOR

Clientes, produtos, vendas



FINANCEIRO

Pagamentos e margem



ADMIN

Acesso total + MFA

Parte A — Ativos e ameaças

1

Pagamentos

AMEAÇA

Força bruta / credential stuffing no login

VULNERABILIDADE

Senha fraca + sem bloqueio

2

Dados de clientes

AMEAÇA

Exploração de vulnerabilidade (ex.: IDOR)

VULNERABILIDADE

Falta de verificação de posse

3

Margem / custo

AMEAÇA

Insider threat (funcionário legítimo)

VULNERABILIDADE

Sem RBAC em nível de campo

B1 — Política de senha

Não basta ser "grande" — precisa ser imprevisível.

8+ caracteres

Letra e número

Fora da lista negra

RECUSADA

"senha123"

Está na lista de padrões óbvios recusados no cadastro.

ACEITA, MAS AINDA FRACA (B4)

"vendedor2024"

Passa na política mínima, mas segue um padrão previsível (palavra+ano)
— alvo real do ataque B5.

B2 — Papéis e permissões (RBAC)

VENDEDOR

- Ver / cadastrar clientes
- Ver produtos
- Lançar vendas

FINANCEIRO

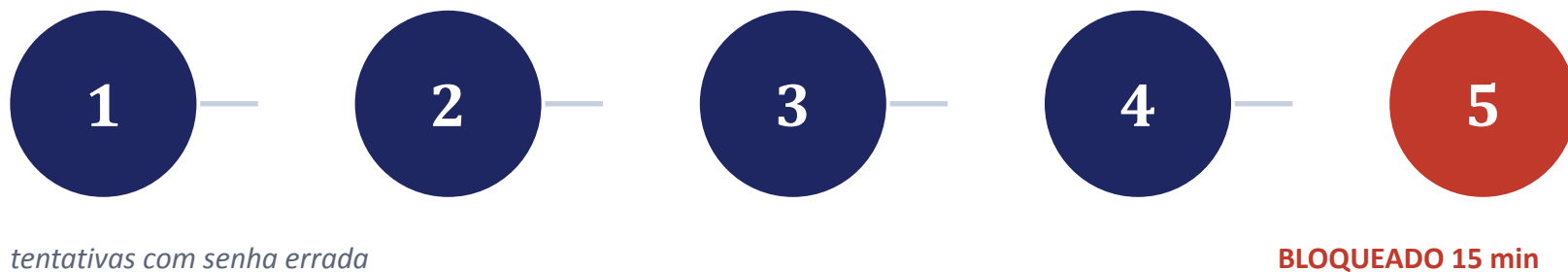
- Ver clientes
- Ver produtos + margem
- Ver pagamentos

ADMIN

- Tudo dos outros papéis
- Gerenciar usuários
- Exige MFA

Mesmo endpoint, resposta diferente: VENDEDOR vê o produto sem o custo; FINANCEIRO vê o custo — RBAC por campo, não só por rota.

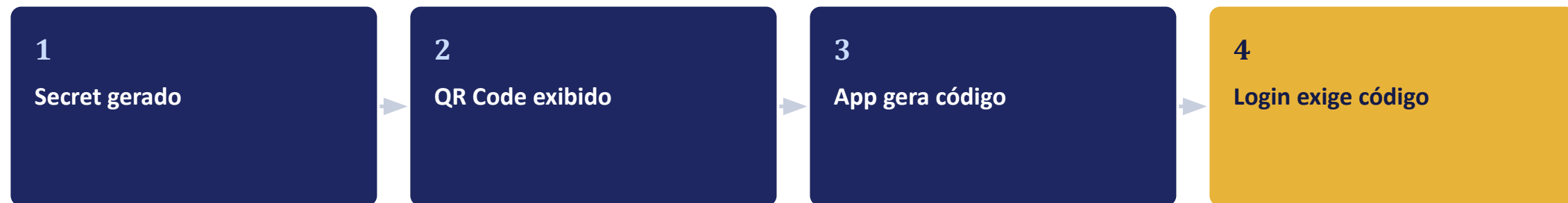
B3 — Login protegido



- Mensagem sempre genérica — nunca diz se foi "usuário não existe" ou "senha errada" (anti-enumeração).
- Timing consistente: mesmo usuário inexistente passa por uma comparação de hash, para não vazar pista pelo tempo de resposta.
- Mesmo com a senha certa, conta bloqueada continua recusando até o tempo passar.

B6 — MFA (TOTP + QR Code)

Obrigatório só para o papel ADMIN



- Código muda a cada 30 segundos — calculado a partir do secret + hora atual, nunca armazenado.
- Defesa em profundidade: mesmo com a senha do ADMIN vazada, falta o segundo fator físico (celular).

Demonstração ao vivo

Ataque de dicionário (B5) contra a conta carlos.vendas

```
python ataque.py
```

```
[1/12] tentando 'vendedor123' -> 401
```

```
[2/12] tentando 'vendedor2023' -> 401
```

```
[3/12] tentando 'vendedor2024' -> 200 SENHA ENCONTRADA
```

Script roda fora do projeto Java — só pela API pública, como um atacante real.

Parte C — Relatório de incidente

O ataque que acabamos de rodar é o incidente documentado.



- A senha passou na política mínima (8+ caracteres, letra e número) mas seguia um padrão previsível.
- O bloqueio por tentativas (B3) não evitou o ataque porque a senha certa apareceu antes da 5ª tentativa.

Conclusão

- Autenticação (quem você é) e autorização (o que pode fazer) são camadas diferentes.
- Defesa em profundidade: senha + bloqueio + RBAC + MFA — nenhum controle sozinho é suficiente.
- O incidente demonstrado mostra exatamente isso: a política de senha bloqueou o óbvio, mas não o previsível.

Perguntas?